



25, June 2026



Cybersecurity Assessment Report:

Altoro Mutual

Comprehensive Vulnerability Analysis & Server Security Audit

Presented By:

Makuei Geu Makuei, Lead Technology Trainer & Security Analyst

Target Application:

Altoro Mutual Web Application

Executive Summary

STRUCTURAL AUDIT CONTEXT

- A comprehensive architectural audit was performed on the Altoro Mutual banking target platform. Employing both Zenmap passive infrastructure tracking and OWASP ZAP proxy assessments, we aimed to map exposures, investigate software status, and isolate security gaps.
- The target system exhibits systemic defensive failures, leaving users vulnerable to session hijacking, downgrade interventions, and administrative interface attacks.

CORE RISK FINDINGS

My combined technical scans isolated 30 distinct alerts within the web layer and multiple critical exposed service instances:

- Unencrypted communication channels (HSTS missing)
- Outdated server application headers (Tomcat 1.1 Coyote)
- Insecure browser cookie flags (No HttpOnly or Secure Flag)
- Vulnerable administrative console exposures (Port 8080)

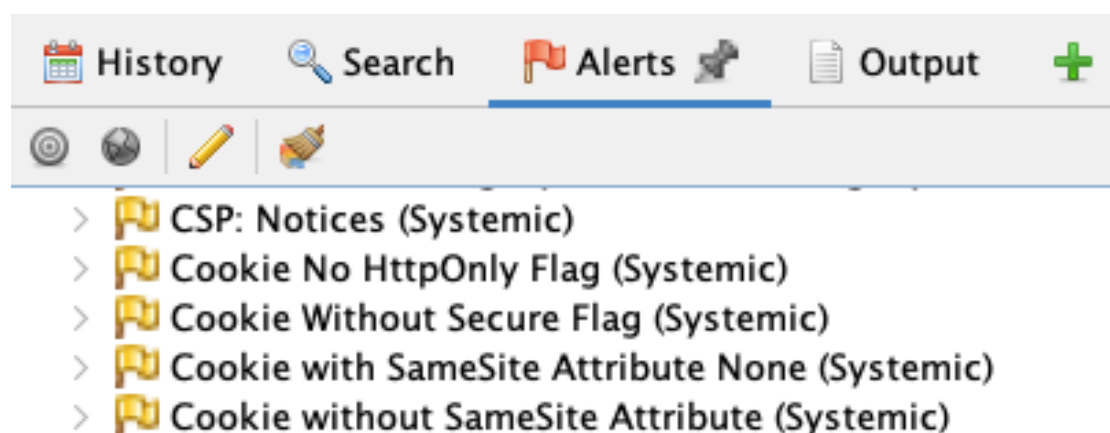
Data Transit Exposure: Insecure HTTP Protocol

CRITICAL FINDING

- The application communicates via unencrypted HTTP instead of secure, encrypted HTTPS.

IMPACT ANALYSIS

- **The Risk:** All data sent between visitors and the application, including login credentials, passwords, and session data, travels across the network in plaintext.
- **The Threat:** Attackers sharing the same local network (e.g., public Wi-Fi) can easily intercept and read sensitive credentials using passive sniffing tools.
- **Risk Level:** HIGH (Severe impact for a banking platform).



Remediation Action:

- Deploy an SSL/TLS Certificate on the web server.
- Configure global rewrite rules to automatically force and redirect all inbound traffic from http:// to https://.

NETWORK FOOTPRINTING (ZENMAP)

Analysis of Service Enumeration via Zenmap

Hosts

Services

OS

Host



demo.testfire.net

Nmap Output

Ports / Hosts

Topology

Host Details

Scans

nmap -sV -F demo.testfire.net

Starting Nmap 7.99 (<https://nmap.org>) at 2026-06-11 15:00 +0300
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.32s latency).
Not shown: 96 filtered tcp ports (no-response)

PORT	STATE	SERVICE	VERSION
80/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
443/tcp	open	ssl/http	Apache Tomcat/Coyote JSP engine 1.1
8080/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
8443/tcp	closed	https-alt	

Active Service Discovery

The application communicates via unencrypted HTTP instead of secure, encrypted HTTPS. As documented in Screenshot 2026-06-11 at 3.03.17 PM.png, executing Nmap service signature scanning on the target host mapped three critical exposed access ports:

- **Port 80/tcp:** Open unencrypted HTTP portal.
- **Port 443/tcp:** Open SSL/HTTP instance.
- **Port 8080/tcp:** Exposed alternative HTTP/Admin panel.

Version Disclosure Risk: All instances broadcast the archaic software string: Apache Tomcat/Coyote JSP engine 1.1. This leaks exact system patches to passive adversaries.

- **Active Reconnaissance:** Executed targeted network footprinting to map open ports, active hosts, and running services across the subnet.
- **Service & OS Detection:** Utilized Nmap/Zenmap service version detection to enumerate precise daemon versions and operating system signatures.
- **Attack Surface Baseline:** Identified critical open vectors and potential entry points to inform the subsequent vulnerability assessment phase.

Passive Reconnaissance: Missing Defensive Guardrails

1

Missing HSTS

Strict-Transport-Security

- **Vulnerability:** Lack of enforced HTTPS connections.
- **Impact:** Without HSTS, browsers are not forced to maintain a secure connection, leaving users highly vulnerable to protocol downgrade attacks.

2

Missing X-Frame-Options

X-Frame-Options

- **Vulnerability:** Missing UI click-protection guardrails.
- **Impact:** Enables malicious sites to render the platform inside an invisible iframe, exposing users to clickjacking attacks where clicks are hijacked.

3

Missing CSP

Content-Security-Policy

- **Vulnerability:** Unrestricted script loading and execution source permissions.
- **Impact:** Drastically increases the success rate of Cross-Site Scripting (XSS) injections by failing to restrict authorised script origins.

- >  Content Security Policy (CSP) Header Not Set (Systemic) 
- >  Cross-Domain Misconfiguration (5)
- >  Missing Anti-clickjacking Header (Systemic) 
- >  Sub Resource Integrity Attribute Missing (Systemic)
- >  CSP: Notices (Systemic)
- >  Cookie No HttpOnly Flag (Systemic)
- >  Cookie Without Secure Flag (Systemic)
- >  Cookie with SameSite Attribute None (Systemic)
- >  Cookie without SameSite Attribute (Systemic)
- >  Cross-Domain JavaScript Source File Inclusion (4)
- >  Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)
- >  Strict-Transport-Security Header Not Set (Systemic) 
- >  Timestamp Disclosure - Unix (Systemic)

OWASP ZAP Alert Analysis

Application-Layer Vulnerability Assessment:

OWASP ZAP Security Header Risk Matrix

Alerts (30)

- > Absence of Anti-CSRF Tokens (3)
- > CSP: Failure to Define Directive with No Fallback (Systemic)
- > CSP: Wildcard Directive (Systemic)
- > CSP: script-src unsafe-eval (Systemic)
- > CSP: script-src unsafe-inline (4)
- > CSP: style-src unsafe-inline (Systemic)
- > Content Security Policy (CSP) Header Not Set (Systemic)
- > Cross-Domain Misconfiguration (5)
- > Missing Anti-clickjacking Header (Systemic)
- > Sub Resource Integrity Attribute Missing (Systemic)
- > CSP: Notices (Systemic)
- > Cookie No HttpOnly Flag (Systemic)
- > Cookie Without Secure Flag (Systemic)
- > Cookie with SameSite Attribute None (Systemic)
- > Cookie without SameSite Attribute (Systemic)
- > Cross-Domain JavaScript Source File Inclusion (4)
- > Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)
- > Strict-Transport-Security Header Not Set (Systemic)
- > Timestamp Disclosure - Unix (Systemic)

The Missing & Weak Content Security Policy (CSP), This makes injecting malicious code (Cross-Site Scripting or XSS) incredibly easy

Absolute lack of an X-Frame-Options. A malicious third-party site can frame Altoro Mutual transparently to hijack user clicks

Missing HSTS Protection, failing to enforce HTTPS

History Search Alerts Output

- > CSP: Notices (Systemic)
- > Cookie No HttpOnly Flag (Systemic)
- > Cookie Without Secure Flag (Systemic)
- > Cookie with SameSite Attribute None (Systemic)
- > Cookie without SameSite Attribute (Systemic)
- > Cross-Domain JavaScript Source File Inclusion (4)
- > Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)
- > Strict-Transport-Security Header Not Set (Systemic)
- > Timestamp Disclosure - Unix (Systemic)
- > X-Content-Type-Options Header Missing (Systemic)
- > Information Disclosure - Information in Browser localStorage (10)
- > Information Disclosure - Information in Browser sessionStorage (7)
- > Information Disclosure - Sensitive Information in URL (3)
- > Information Disclosure - Suspicious Comments (20)
- > Loosely Scoped Cookie (Systemic)
- > Modern Web Application (Systemic)
- > Re-examine Cache-control Directives (Systemic)
- > Retrieved from Cache (Systemic)
- > Session Management Response Identified (13)
- > User Controllable HTML Element Attribute (Potential XSS) (4)

Insecure Session Tracking (The Cookie Flaws). A suspected, the application's session management tokens are highly exposed.

Server Information Leakage; The web server is actively broadcasting its software version strings to anyone who asks, letting attackers map out targeted exploits instantly.

OWASP ZAP Alert Analysis

OWASP ZAP Security Header Risk Matrix

Finding / Alert	Severity	Risk Description	Remediation Strategy
HTTP Strict Transport Security (HSTS)	HIGH	Lack of HSTS header allows connections to downgrade to unencrypted HTTP, exposing users to MITM attacks.	Enforce the Strict-Transport-Security header across all production domains and subdomains.
Content Security Policy (CSP)	MEDIUM	Missing or poorly configured CSP allows unauthorized scripts to run, increasing Cross-Site Scripting (XSS) risks.	Define strict Content-Security-Policy directives to restrict script execution sources to trusted origins.
Clickjacking Protection	LOW	Absence of anti-framing headers (X-Frame-Options / CSP frame-ancestors) allows malicious page framing.	Implement X-Frame-Options: DENY or use the CSP frame-ancestors 'none' directive to prevent UI redressing.

AUDIT STATUS: COMPLETE

AWAITING DEVELOPER REMEDIATION SIGN-OFF

Makuei Geu Makuei; Security Analyst